

THREAT ADVISORY



ATTACK REPORT

BumbleBee leverages Zerologon to get Domain Controller Access

Date of Publication

November 15, 2022

Admiralty Code

A1

TA Number

TA2022257

Summary

First Activity Observed: May 2022
Affected Product: Windows Server
Attack: BumbleBee used by threat actors to load Meterpreter agents and Cobalt Strike Beacons.

CVEs

CVE	NAME	PATCH
CVE-2020-1472	Netlogon Elevation of Privilege Vulnerability (Zerologon)	

Attack Details

#1

Since May 2022, threat actors are leveraging BumbleBee as an initial vector from a Contact Forms campaign. The intrusion started with the delivery of an ISO file that contained an LNK and a DLL. Using BumbleBee, the threat actors loaded Meterpreter and Cobalt Strike Beacons.

#2

As part of their attack, they performed reconnaissance, bypassed UAC using two different techniques, stole credentials, escalated privileges using a ZeroLogon exploit, and moved laterally through the environment.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0011</u> Command and Control
<u>TA0004</u> Privilege Escalation	<u>TA0005</u> Defense Evasion	<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery
<u>TA0008</u> Lateral Movement	<u>T1187</u> Forced Authentication	<u>T1102</u> Web Service	<u>T1547</u> Boot or Logon Autostart Execution
<u>T1003</u> OS Credential Dumping	<u>T1003.001</u> LSASS Memory	<u>T1003.002</u> Security Account Manager	<u>T1018</u> Remote System Discovery
<u>T1021</u> Remote Services	<u>T1021.002</u> SMB/Windows Admin Shares	<u>T1036</u> Masquerading	<u>T1055</u> Process Injection
<u>T1057</u> Process Discovery	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.003</u> Windows Command Shell	<u>T1059.001</u> PowerShell
<u>T1068</u> Exploitation for Privilege Escalation	<u>T1069</u> Permission Groups Discovery	<u>T1069.002</u> Domain Groups	<u>T1070</u> Indicator Removal on Host
<u>T1070.004</u> File Deletion	<u>T1071</u> Application Layer Protocol	<u>T1071.001</u> Web Protocols	<u>T1078</u> Valid Accounts
<u>T1082</u> System Information Discovery	<u>T1087</u> Account Discovery	<u>T1087.002</u> Domain Account	<u>T1135</u> Network Share Discovery
<u>T1204</u> User Execution	<u>T1204.002</u> Malicious File	<u>T1218</u> Signed Binary Proxy Execution	<u>T1218.011</u> Rundll32
<u>T1548</u> Abuse Elevation Control Mechanism	<u>T1548.002</u> Bypass User Account Control	<u>T1550</u> Use Alternate Authentication Material	<u>T1550.002</u> Pass the Hash
<u>T1553</u> Subvert Trust Controls	<u>T1553.005</u> Mark-of-the-Web Bypass	<u>T1566</u> Phishing	<u>T1566.002</u> Spearphishing Link
<u>T1569</u> System Services	<u>T1569.002</u> Service Execution	<u>T1570</u> Lateral Tool Transfer	

✂ Indicator of Compromise (IOC)

TYPE	VALUE
MD5	EE7AD5FE821FB9081380DBBF40C4F062 AEFF99611BABD41D79C3BA7930F00BC1 B3E68AEBE05DC652EC65099E0E98B94E FBCAA31456F39F996950511705461639 BD5C8EA8C231BF2775B9C0BA3F7EA867 EA2C1FA8668812852A77737C4F712BA2 5D2A8724DBCE65EEFB7E74FBB0ECEDA9
SHA256	3C600328E1085DC73D672D068F3056E79E66BEC7020BE6AE9 07DD541201CD167 DF63149EEC96575D66D90DA697A50B7C47C3D7637E18D4DF 1C24155ABACBC12 4BB67453A441F48C75D41F7DC56F8D58549AE94E7AEAB48A7 FFEC8B78039E5CC 65A9B1BCDE2C518BC25DD9A56FD13411558E7F24BBDBB8CB 92106ABBC5463ECF F7C1D064B95DC0B76C44764CD3AE7AEB21DD5B161E5D218E 8D6E0A7107D869C1 DA3C4E2B7768D66ECB6C0E74C6D45E2BCFBC6203B76C71639 09BD2061603CEF5 F7BFDE050C81D47D79FEBDB170F307F447E76253715859727 BEFF889D2A91694
SHA1	38EEF0CDAA8FAA27C9E2CEDEAFCFE842E2E0E08E FA3649B0472BA7FD9B31A22C904B2DE4C008F540 52D4C0CB9A93E7BC5F1E0C386DCCA3E0AC41B966 759688D1245AACD0ED067B0F0388786E911AAF28 CCC9E1559B877B04B1D0E7F8920A64B4E35136DA FA9597B87F78C667CC006AAA1C647D539AA9B827 785B660537506501E695E46875B02260649B23F7
IPV4:PORT	45[.]153.243.93:443 213[.]232.235.199:443 172[.]93.201.12:443 23[.]106.215.100:443 3[.]16.159.37:80 3[.]16.159.37:44
Domains	cevogesu[.]com titojukus[.]com ec2-3-16-159-37.us-east-2.compute.amazonaws[.]com

TYPE	VALUE
JA3	AE4EDC6FAF64D08308082AD26BE60767 0C9457AB6F0D6A14FC8A3D1D149547FB 61BE9CE3D068C08FF99A857F62352F9D CE5F3254611A8C095A3D821D44539877 A0E9F5D64349FB13191BC781F81F42E1 EC74A5C51106F0419184D0DD08FB05BC

🔗 Patch Link

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2020-1472>

🔗 References

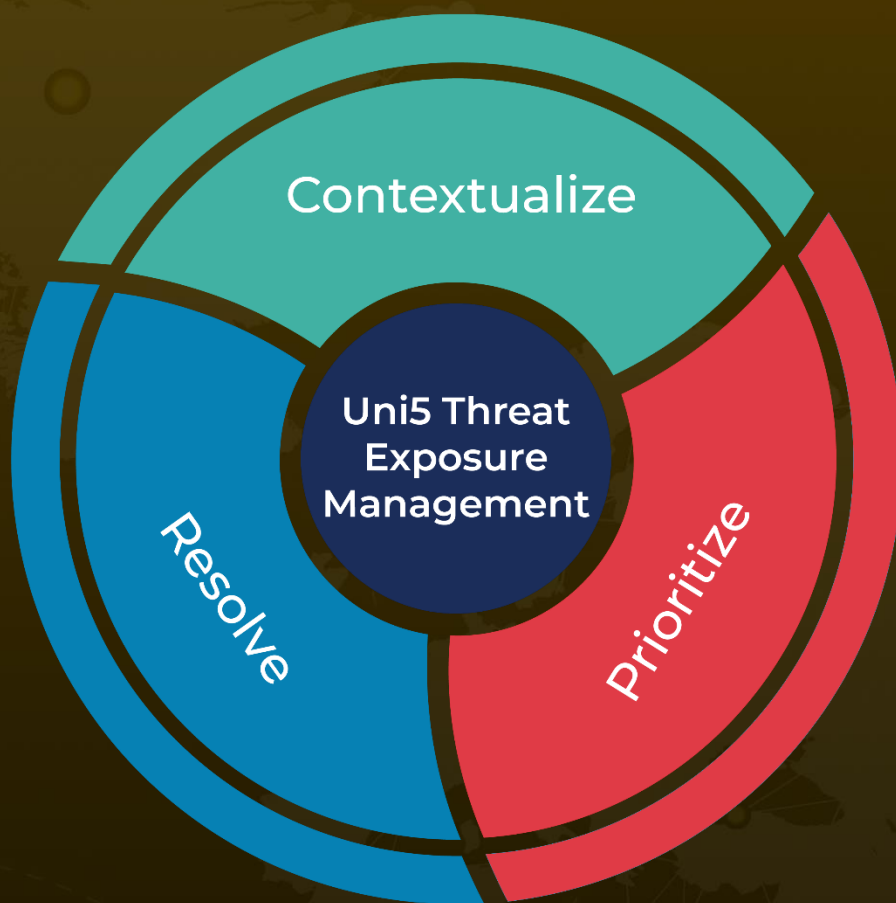
<https://thedfirreport.com/2022/11/14/bumblebee-zeros-in-on-meterpreter/>

<https://otx.alienvault.com/pulse/6372065507295a08625c3cdf/>

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 15, 2022 • 5:30 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com